

Aragon AI Assistant — FAQ Sécurité & Sûreté

Système : Aragon Maestro | Modèle : Qwen (via llama.cpp) | Interface : llama-ui + serveurs MCP personnalisés

Audience : Clients et utilisateurs finaux

Dernière mise à jour : Juin 2026

Présentation

Ce document répond aux questions les plus fréquentes des clients concernant le modèle d'IA utilisé dans l'assistant Aragon, son profil de sécurité, et les mesures spécifiques mises en place pour protéger les données des utilisateurs et l'intégrité du système. Il se veut honnête, transparent et techniquement précis.

Q1 — Quel modèle d'IA Aragon utilise-t-il, et pourquoi est-il parfois qualifié d'« unsafe » (non sécurisé) ?

Le modèle

Aragon utilise **Qwen**, une famille de grands modèles de langage (LLM) développée par **Alibaba Cloud** et publiée sous forme de modèles open-weight sous licences permissives[cite:16]. La variante utilisée s'exécute localement via **llama.cpp**, un moteur d'inférence open-source largement répandu.

Ce que signifie réellement « unsafe »

Le terme « unsafe » dans la littérature sur la sécurité de l'IA ne signifie **pas** que le système est dangereux à utiliser ou que vos données sont à risque. Il désigne spécifiquement des **faiblesses dans les garde-fous de contenu** — c'est-à-dire que le modèle peut parfois être manipulé (via des entrées adversariales appelées « jailbreaks ») pour générer du texte nuisible comme du code malveillant, des recettes dangereuses ou du contenu frauduleux[cite:5][cite:7].

Des évaluations indépendantes ont jugé les modèles Qwen critiquement faibles sur cette dimension[cite:3]. Des problèmes comparables existent dans des modèles comme DeepSeek et, dans une moindre mesure, dans des modèles occidentaux tels que GPT-4 et Llama[cite:4]. Aucun LLM commercial n'est aujourd'hui considéré comme totalement sûr face à toutes les entrées adversariales.

Ce que cela signifie en pratique

Pour le déploiement Aragon :

- Toutes les entrées du modèle passent par une **sanitisation des prompts** avant d'atteindre le modèle
- Toutes les sorties du modèle sont encadrées par des **serveurs MCP personnalisés** qui restreignent les actions possibles
- Le modèle n'a **aucun accès à Internet** pendant l'inférence
- L'assistant **n'est pas adapté aux décisions critiques ou à haut risque** (conseils médicaux, juridiques ou financiers nécessitant une conformité réglementaire)

Q2 — Qwen est-il un modèle chinois ? Mes données risquent-elles de partir en Chine ?

Origine du modèle vs. destination des données

Qwen est développé par Alibaba Cloud, une entreprise chinoise, et est soumis à la juridiction chinoise dans sa version cloud[cite:1]. Cependant, le déploiement Aragon utilise la **version open-weight** de Qwen — les poids du modèle sont téléchargés une seule fois et s'exécutent entièrement sur une infrastructure locale[cite:36][cite:45].

Cela signifie :

- Aucune requête, prompt ou réponse n'est envoyé aux serveurs d'Alibaba Cloud
- Aucun appel API n'est effectué vers un service externe pendant l'inférence
- Alibaba n'a aucune capacité technique d'accéder aux données de conversation

Implications RGPD

Comme tout le traitement est local, le déploiement satisfait à l'**Article 25 du RGPD** (protection des données dès la conception) et évite les obligations de l'**Article 44** sur les transferts transfrontaliers de données[cite:36]. L'opérateur agit en tant qu'**utilisateur d'un modèle open-weight**, et non en tant qu'abonné à un service cloud — un rôle juridiquement distinct et moins risqué au sens de la loi sur l'IA de l'UE.

Q3 — Le système est-il sûr à 100 % ?

La réponse honnête

Aucun système d'IA n'est sûr à 100 % — et tout fournisseur affirmant le contraire doit être questionné. L'assistant Aragon offre des garanties solides et vérifiables, mais comme tous les systèmes basés sur des LLM, il comporte des limites inhérentes que les clients doivent comprendre.

Ce qui est garanti :

- Les données des utilisateurs ne quittent pas l'infrastructure locale[cite:36][cite:45]
- Les poids du modèle ne contiennent pas de code exécutable ni de mécanismes d'exfiltration cachés — le format GGUF (utilisé par llama.cpp) est un format de poids non exécutable[cite:40]
- L'accès aux outils (système de fichiers, API, commandes shell) est contrôlé exclusivement via des serveurs MCP à périmètre défini ; le système n'expose pas de commandes au niveau OS[cite:31]
- L'intégrité des checkpoints du modèle est vérifiable via des hachages SHA-256 comparés aux versions officielles Qwen sur HuggingFace[cite:34]

Ce qui ne peut pas être garanti :

- L'exactitude factuelle de toutes les réponses — les LLM peuvent halluciner ou produire des informations incorrectes mais plausibles
- Une résistance parfaite aux prompts adversariaux — un utilisateur déterminé peut obtenir des sorties inattendues[cite:43]
- L'adéquation pour des décisions à enjeux élevés — l'assistant est conçu pour un usage général, non pour des domaines réglementés ou critiques

Q4 — Comment les clients peuvent-ils vérifier ces affirmations ?

Des preuves techniques sont disponibles sur demande pour chaque affirmation :

Affirmation	Méthode de vérification
Pas de transmission de données sortantes	Capture du trafic réseau (Wireshark/tcpdump) lors d'une session d'inférence en direct, sans connexion externe
Poids du modèle propres	Hachage SHA-256 des fichiers GGUF comparé aux checksums officiels Qwen sur HuggingFace[cite:34]
Poids non exécutables	Revue du code source de llama.cpp confirmant que le GGUF est interprété uniquement, sans chemin d'exécution shell depuis les poids[cite:40]
Accès aux outils MCP délimité	Revue de la configuration du serveur MCP indiquant les limites de permissions explicites[cite:33]
Pas d'exposition shell au niveau OS	Confirmation que llama.cpp ne s'exécute pas avec le flag <code>--tools all</code> , qui exposerait <code>exec_shell_command</code> et les outils I/O fichiers[cite:31]
Sanitisation des entrées active	Revue du code du pipeline de prétraitement des prompts avant invocation du modèle

Q5 — Quels risques subsistent et comment sont-ils gérés ?

Risques résiduels

Risque	Probabilité	Mesure d'atténuation
Hallucination (réponses fausses mais confiantes)	Moyenne	Revue humaine recommandée pour toute décision ; l'assistant ne doit pas être la seule source de vérité
Injection de prompt via entrée adversariale	Faible–Moyenne	Couche de sanitisation des entrées ; le serveur MCP restreint le périmètre des outils[cite:33][cite:43]
Comportement agentique inattendu	Faible	Pas d'accès Internet autonome ; les appels d'outils nécessitent des autorisations MCP explicites[cite:31]
Biais du modèle ou sorties filtrées politiquement	Faible (modèle local)	Pas de filtrage de contenu en direct par Alibaba ; le comportement du modèle est statique après déploiement
Compromission de la chaîne d'approvisionnement GGUF	Très faible	Seules les versions officielles Qwen sont utilisées ; checksums vérifiés au téléchargement[cite:34][cite:40]

Ce qui n'est pas un risque dans ce déploiement

- **Données envoyées en Chine** : Impossible — pas d'appels API, inférence totalement hors ligne[cite:36][cite:45]
- **Surveillance en temps réel** : Le modèle n'a pas de mémoire persistante entre les sessions sauf si explicitement implémentée
- **Malware dans les poids** : Le format GGUF ne peut pas exécuter de code arbitraire ; llama.cpp est le seul runtime[cite:40]

Résumé pour les clients

L'assistant Aragon utilise Qwen, un modèle open-weight s'exécutant entièrement sur une infrastructure locale sans transmission de données vers l'extérieur. L'étiquette « unsafe » dans les benchmarks de sécurité IA désigne des faiblesses de garde-fous de contenu partagées par pratiquement tous les LLM actuels — et non des risques liés à la sécurité des données ou à la surveillance. L'architecture de déploiement local élimine les principales préoccupations associées aux modèles d'origine chinoise. Des preuves techniques vérifiables pour toutes les affirmations de sécurité sont disponibles sur demande.

Pour toute décision critique, exercez toujours votre jugement humain. L'assistant est un outil, pas une autorité.